Pericope Demo Runbook & Product KT

Nov 3, 2026 · @Sam

Everything you need to demo Pericope to a guest and explain it end to end: what each screen does and why, a timed demo script, live test cases, edge cases, recovery steps and answers to likely questions.

Pericope in one page

Pericope is an enterprise risk management (ERM) platform: one place where a company finds its risks, scores them, puts controls on them, gets them approved and watches them over time, with a tamper-evident record of who did what.

The problem it solves. Most companies run risk in spreadsheets and e-mail. That causes five recurring failures:

Failure in spreadsheets	What Pericope does instead
Every department scores risk differently	One 5 × 5 likelihood × impact scale, one set of score bands, set once by the administrator
Nobody knows which version is current	One shared register in an Oracle database; every screen reads live data
Anyone can mark their own work as approved	Maker-checker: the person who submits can never approve; the server enforces it
No proof of who changed what	Every change goes into an audit trail sealed with a hash chain, so edits or deletions are detected
Risk is a once-a-year exercise	Assessment cycles each quarter, key risk indicators (KRIs) with traffic lights, overdue actions surfaced on the dashboard and the bell

Who it is for. Mid-size and large companies with several departments: the Chief Risk Officer and risk team run it; department heads own their risks; internal audit reads everything; the board gets the reports. It is not industry-specific: the same screens work for manufacturing, services, retail, finance or the public sector.

The method it follows. RCSA, Risk and Control Self-Assessment, in five steps that match the left-hand menu: plan a cycle → identify risks → rate inherent risk → apply controls and rate residual risk → monitor. Around that core sit KRIs, risk appetite, policies, vendors,

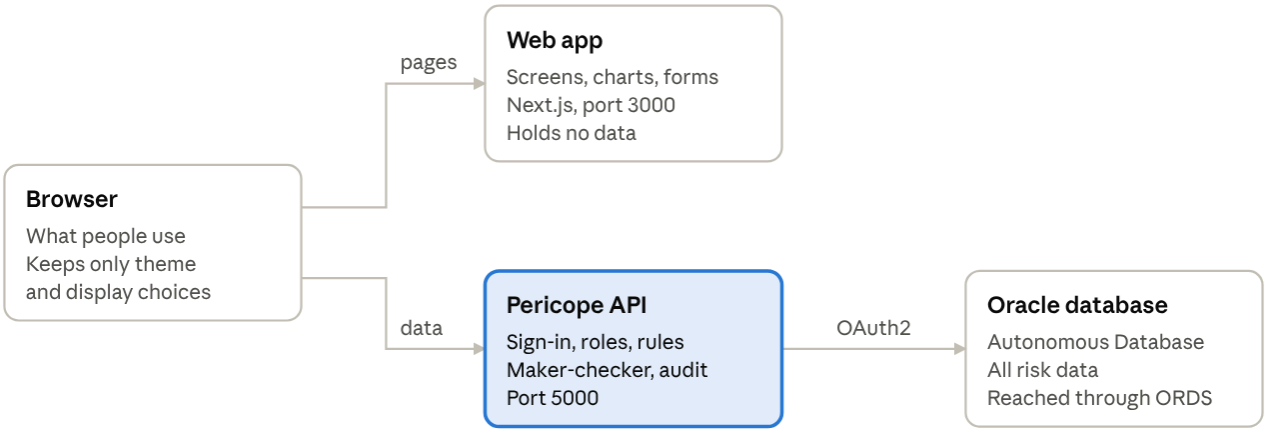
incidents, business continuity, scenarios, approvals, reports and the audit trail.

What makes it different, in one line each:

- **Real data only.** No invented numbers: an unrated risk shows as "Not rated", never a guessed score.
- **Controls are enforced on the server**, not only hidden in the UI, so a tampered browser cannot bypass them.
- **Evidence by design.** The audit trail re-verifies its own integrity every time it is opened.
- **Runs on Oracle Autonomous Database**, with two small Docker images for the web app and API.

How it works

The browser never talks to the database: every request passes the API



Pericope architecture · 4 parts

The web app only draws screens; every read and write goes to the API, which checks who the person is and what their role allows, then talks to Oracle with its own OAuth2 credentials. That is why rules such as "no self-approval" cannot be bypassed from the browser.

Part	What to say about it
Web app	Modern single-page app; light and dark themes; works on laptops and phones
API	One TypeScript service: sign-in, roles, validation of every field, approval rules, settings, the hash-chained audit log, user accounts

Part	What to say about it
Oracle Autonomous Database	Holds every risk, control, KRI, policy, vendor, incident and plan; REST access requires a token
Hosting	Two Docker containers (or plain Node.js) behind HTTPS; the database is managed by Oracle Cloud

Roles and permissions

Five roles; each person has exactly one, set by an administrator under **Administration → Users**. The API enforces every rule; the screens also hide buttons a person cannot use.

Role	Create & edit	Delete	Approve / reject	Audit trail	Users & settings	Typical person
Administrator	Yes	Yes	Yes (never own work)	Yes	Yes	Platform owner, CRO's deputy
Risk Manager	Yes	Yes	Yes (never own work)	Read	No	Risk team, approvers
Assessor	Yes, and submit for approval	No	No	No	No	Department heads, risk champions
Auditor	No	No	No	Read	No	Internal or external audit
Viewer	No	No	No	No	No	Executives, guests

Rules worth saying out loud in a demo:

- **Nobody approves their own work**, not even an Administrator. The server checks who created or submitted the record.
- **Risk appetite can only be changed by approvers** (Risk Manager, Administrator): appetite is a board decision.
- **A rejection needs a comment**, so the submitter knows what to fix.
- **Changing someone's role or deactivating them signs them out immediately.**
- Sign-in needs a password of 12+ characters with letters and numbers; 5 wrong passwords lock the account for a while; idle sessions sign out after the time set in Settings (default 30 minutes).

Every feature: what it does and why it is there

The left menu has six groups. Each row below is one screen: where to find it, what it does, and the problem it solves.

Whole-app features

Feature	What it does	Why it is there
Sign-in	E-mail and password; secure session cookie; lockout after repeated failures	Only named people get in, and every action is tied to a person
Command palette (Ctrl+K / ⌘K)	Searches risks, controls, KRIs, vendors, policies, incidents, pages and actions from one box	Find anything in two keystrokes instead of clicking through menus
Attention bell (top bar)	Lists what needs you now: approvals waiting for you, KRIs in red or amber, overdue action plans	Nobody has to remember to check; problems come to the user
Breadcrumbs	Show where you are, using record names, not ids	Orientation on deep pages
User menu	Light / dark theme, comfortable / compact density, change password, sign out	Personal comfort; dark mode for long sessions
Collapsible sidebar	Grouped by the RCSA lifecycle, with a live approvals count; becomes a drawer on phones	The menu teaches the method: steps 1–5 in order
Idle sign-out	Signs out after the idle time set in Settings	A forgotten open laptop does not stay signed in
Print	Every report prints as an A4 board pack, always on white paper	Board papers straight from the app

Dashboard

Screen	What it does	Why it is there
Dashboard	Live headline figures: risks by band, recorded loss expectancy (SLE), control coverage (% of risks with at least one control), overdue action plans, KRIs in red or amber, open incidents, approvals waiting for you; risk trend over time	One-minute picture of the company's risk for a CRO or executive, all computed from the database

RCSA lifecycle (the core, steps 1–5)

Step	Screen	What it does	Why it is there
1	Assessment cycles	Create and run review periods (e.g. "Q4 2026 RCSA") with dates, deadline and status (Planned, In Progress, Under Review, Completed); each shows its count of risks, rated risks and approved risks	Turns risk review into a repeatable quarterly rhythm with a deadline
2	Risk register	The master list of risks: statement, category, process, owner, champion, ratings, approval status. Paged, searchable, sortable, filterable; "Awaiting approval" view; CSV import (reports each bad row) and export; add, edit, delete	One trusted register replaces departmental spreadsheets
—	Risk page (click any risk)	Everything about one risk: inherent and residual scores, applied controls, monitoring actions, linked incidents, approval history, Submit / Approve / Reject buttons	The full story of a risk on one screen, for reviewers and auditors

Step	Screen	What it does	Why it is there
3	Inherent assessment	Rate a risk's likelihood (1–5) and impact (1–5) before controls, with a description; each save is kept as an assessment record with date and author	Establishes how bad the risk is if nothing is done
4	Controls & mitigation	Apply controls from the library to a risk, record design and operating effectiveness and evidence, rate residual likelihood and impact; shows the reduction	Shows whether the controls actually bring risk down to an acceptable level
5	Monitoring	Action items per risk with owner, dates, percentage complete and type (periodic review, control enhancement, new control proposal); overdue worked out from dates	Makes sure the promised fixes happen
—	Action plans & plan hierarchy	Mitigation plans as a tree (programme → workstreams) with status Not Started, In Progress, On Hold, Completed, Cancelled	Big fixes are run as programmes with parts
—	RCSA overview	Live counts for each lifecycle stage	Shows where the cycle is stuck

Analytics

Screen	What it does	Why it is there
Heatmaps	5 × 5 grid of likelihood × impact in three modes: Inherent, Residual, Movement (arrows show how far controls moved each risk); click a cell to list its risks; keyboard navigable	The classic board picture of where risk sits and whether controls work

Screen	What it does	Why it is there
Residual analysis	Inherent vs residual by risk and category; counts of risks not yet assessed	Proves the value of controls in numbers
Key risk indicators (KRIs)	Register of indicators with thresholds and direction (higher-is-worse or lower-is-worse); record readings; history chart; traffic light per reading; matrix and threshold editor	Early warning: numbers that move before the risk happens
Reports	Six live reports: Risk register, Control library summary, KRI status, Vendor summary, Incident summary, Audit trail summary; CSV export and print	Board and regulator packs in one click, always current

Controls & policy

Screen	What it does	Why it is there
Control library	Every control with code, type (preventive, detective, corrective, compensating), nature (manual, automated, hybrid), frequency, owner, frameworks, design and operating effectiveness, last tested; link to risks; CSV export; a control in use cannot be deleted, only retired	Controls are written once and reused across risks, so testing evidence is shared
Risk appetite	Board-approved statements per category with posture (Averse, Cautious, Open, Hungry) and a tolerance score; **current exposure is computed** from the rated risks in that category	Tells management at a glance where the company takes more risk than the board allows
Approvals	Maker-checker inbox with tabs Waiting for me, My requests, All; multi-step requests decided in order by role; tells you why you cannot decide a request; a rejection needs a comment; submitter can withdraw	Formal sign-off with segregation of duties

Screen	What it does	Why it is there
Policies	Policy register with owner, version, effective date, next review, acknowledgement %, linked controls; review due and overdue computed from dates	Shows policy coverage and which policies are stale

Enterprise risk

Screen	What it does	Why it is there
Vendors	Third parties by tier (Critical to Low), status, contract value, risk score, review dates, open findings; overdue reviews flagged	Third-party failure is a top cause of operational loss
Incidents	Loss events with severity, status, category, owner, dates, root cause, corrective action, loss amount; link to risks; closed date set automatically	Real losses feed back into how risks are rated
Business continuity	Continuity plans with RTO and RPO (recovery time and data-loss targets), owner, test dates; the database enforces RPO ⩽ RTO; business process library	Proves the company can recover critical processes
Scenarios	Stress tests and what-ifs with shock %, baseline and stressed loss, probability; expected loss and loss uplift calculated	Looks beyond day-to-day risk to severe but plausible events

Administration

Screen	What it does	Why it is there
Audit trail	Every sign-in, failed sign-in, data change, approval and user change, with who, when and what; searchable; an **integrity seal** re-verifies the hash chain on load	Evidence for auditors and regulators that nothing was quietly changed

Screen	What it does	Why it is there
Users	Create people, set role and department, deactivate, reset password	Access control without a database administrator
Settings	Organisation name, industry, currency (10 choices), idle sign-out minutes, and the score bands with a live preview	One switch changes money formatting and score colours everywhere

Key concepts to explain

Seven ideas carry the whole product. Learn these and every screen makes sense.

1. Risk score = likelihood × impact. Both are rated 1–5, so a score runs from 1 to 25.

Rating	Likelihood	Impact
1	Rare	Insignificant
2	Unlikely	Minor
3	Possible	Moderate
4	Likely	Major
5	Almost certain	Severe

2. Bands turn a score into a word and a colour. Defaults, changeable in Settings:

Band	Score
Low	1–6
Moderate	7–11
High	12–15
Critical	16–25

Example to use: likelihood 4 × impact 5 = **20, Critical**. Change the bands in Settings and every colour in the app follows.

3. Inherent vs residual. Inherent = how bad the risk is with no controls. Residual = how bad it is after the controls you apply. The gap between them is the value of your controls; the heatmap's Movement mode draws it as arrows.

4. "Not rated" is honest. A risk without ratings shows a hatched "Not rated" badge, never a made-up score. This is deliberate: old tools invented numbers.

5. Maker-checker. One person makes (creates, edits, submits), another checks (approves or rejects). Status runs Draft → Submitted → Approved or Rejected. The server refuses self-approval, and a rejection must carry a reason.

6. KRIs and direction. A KRI is a number tracked over time, e.g. unplanned outage hours per month. Each has green, amber and red thresholds and a direction: for "higher is worse" a reading at or above red is red; for "lower is worse" a reading at or below red is red. The app colours each reading itself, so nobody marks their own indicator green.

7. The audit seal. Each audit entry stores a fingerprint (hash) of the entry before it, like links in a chain. Changing or deleting any old entry breaks the chain, and the Audit trail page shows the seal as broken. That is what "tamper-evident" means.

Two more terms you will be asked about:

- **SLE (single loss expectancy):** the estimated money lost if the risk happens once. Shown in the organisation's currency.
- **RCSA (risk and control self-assessment):** departments assess their own risks and controls each cycle; the risk team reviews and approves.

The demo company: Meridian Group

The database holds a fictional multi-department enterprise running an ERP. Every person is invented and every e-mail ends in @example.com. Say so if asked: it is demo data, and real data replaces it.

Departments (10): Finance · Human Resources · Sales & Marketing · Procurement & Supply Chain · Manufacturing & Operations · Information Technology · Legal & Compliance · Customer Service · Research & Development · Risk & Internal Audit.

ERP process areas (9): Order to Cash · Procure to Pay · Record to Report · Hire to Retire · Plan to Produce · Inventory & Logistics · IT Operations · Customer Service · Product Development.

Cycles: five, so every stage of the method has data to show.

Cycle	Status	Risks	What it proves to the guest
Q2 2026 RCSA	Completed	6, all approved	A finished cycle: rated, controlled, actions done, plans completed
Q3 2026 RCSA	Under Review	6: 3 approved, 3 submitted	Risk managers part-way through reviewing
Q4 2026 RCSA	In Progress	6: 3 draft, 1 submitted, 1 in review, 1 rejected	Live work at every stage, including a not-rated risk and an overdue action
Q1 2027 RCSA	Planned	0	The next cycle, set up and waiting to start

Data at every step of the lifecycle (after `install_all.sql` and `10_more_demo_data.sql`): 18 risks registered · 19 inherent assessment records (one is an earlier rating, so that risk's history shows how its score changed) · 13 controls applied to risks · 6 monitoring actions from 10% to 100% complete, one overdue · 6 mitigation plans covering all five statuses (Not Started, In Progress, On Hold, Completed, Cancelled) · 7 incident links.

The risk register: 18 risks. 9 approved, 4 submitted, 1 in review, 3 draft, 1 rejected; one is not yet rated. They span all 10 departments. The risks to use in the demo:

Use it to show	Risk	Owner	Inherent → residual	Status
The headline risk, heatmap movement	ERP outage stops order processing and invoicing for more than a day	Marcus Lee (CIO)	4×5 = 20 Critical → 3×3 = 9 Moderate	Approved
Cyber and controls	Ransomware encrypts the ERP and file servers	Marcus Lee	3×5 = 15 High → 2×4 = 8 Moderate	Approved
Approving live (maker-checker)	Failure of a single-source supplier halts a production line	Kenji Watanabe (Supply Chain)	4×4 = 16 Critical → 3×3 = 9 Moderate	Submitted

Use it to show	Risk	Owner	Inherent → residual	Status
A rejection with a reason	New e-invoicing and data-protection rules not implemented on time	Fatima Al-Sayed (Compliance)	3×3 = 9 Moderate → 2×3 = 6 Low	Rejected
"Not rated" honesty	New product launch delayed by R&D overruns	Lina Park (R&D)	Not rated	Draft
Health & safety, non-financial risk	Serious workplace injury on the factory floor	Tom Becker (COO)	3×4 = 12 High → 2×3 = 6 Low	Submitted
Strategic risk	Three largest customers make up 45% of revenue	Carlos Mendes (Sales)	3×4 = 12 High → 3×3 = 9 Moderate	Draft

Around the register:

- **Control library (8):** MFA on all production systems, daily bank reconciliation, incident response playbook, annual GDPR training, encrypted off-site backup, vendor due-diligence questionnaire, segregation of duties for payments, regulatory horizon scanning.
- **KRIs (4):** Unplanned IT outage hours, Critical customer support escalations, Operating cash buffer (lower is worse), Overdue audit remediation items; monthly readings from December 2025 to October 2026. The latest reading is red for outage hours and amber for the other three, so the dashboard and the bell show breaches.
- **KPIs (4):** RCSA completion on time, Overdue risk actions, Key controls tested, Mean time to close incidents; six months of actuals.
- **Incidents (8):** Online payment gateway errors at month-end, spear-phishing of the treasury team, a delayed bank reconciliation report, a vendor security notice, a forklift collision, a supplier invoice paid twice, an ERP slowdown at quarter-end and a contract sent to the wrong customer. Each is linked to a risk; two are still open.
- **Vendors (6),** from Cloudbase Hosting (Critical) to Streamline Print Co (Medium).
- **Policies (5),** including the Personal Data Protection Policy, whose review is overdue: good for showing date-driven warnings.
- **Continuity plans (4)**, **scenarios (3)**, **risk appetite statements (8)**, **approval requests (4)**, plus monitoring actions and a two-programme mitigation-plan hierarchy (Cyber resilience, Supply-chain resilience).

Important: app logins are separate from these people. The people above are records in the database, not sign-in accounts. Create demo logins under **Administration → Users** before the demo (see the checklist).

Before the guest arrives

Do this 30 minutes before. Every item takes under a minute.

The day before

- [ ] Run `node api/scripts/check-db.mjs`: all three lines ✓.
- [ ] Open `<API address>/ready`: shows `"database":"ok"`.
- [ ] Create three demo logins under **Administration → Users** (passwords of 12+ characters with letters and numbers), and write them down off-screen:
  - an **Assessor** (e.g. "Asha Assessor"), to create and submit
  - a **Risk Manager** (e.g. "Ravi Manager"), to approve
  - a **Viewer** (e.g. "Guest Viewer"), to show read-only access
- [ ] Sign in once with each to confirm it works.
- [ ] Decide whether to start fresh: re-running `install_all.sql` resets all demo data (and the OAuth client stays as is). Run `09_oauth_client.sql` only if you need a new secret.

30 minutes before

- [ ] Both services running: the API window shows `Pericope API listening`; the website loads.
- [ ] Use Chrome or Edge, zoom 100%, window full screen, bookmarks bar hidden.
- [ ] Three browser profiles or windows (normal + two private/incognito), one per demo login, so you can switch person without signing out.
- [ ] Sign in as Administrator in the main window; open the Dashboard.
- [ ] Light theme for projectors (user menu → theme); comfortable density.
- [ ] Check Settings: organisation name, currency and bands are what you want to show.
- [ ] Turn off notifications; close Slack, e-mail and anything showing `.env`, the OAuth secret or database pages.
- [ ] Have this runbook open on a second screen or printed.
- [ ] Keep a backup: screenshots of the Dashboard, Heatmap, a Risk page and the Audit trail in a folder, in case the network fails.

Never show on screen

- `api/.env`, the OAuth client id or secret, database passwords, the Database Actions SQL page.

The demo script (20 minutes)

The story: **"A new risk appears, gets rated, controlled, approved by someone else, and lands in the board report, with proof of every step."** Tell that in one sentence first, then show it. Times are cumulative.

Time	Screen	Do this	Say this
0:00	Sign-in page	Sign in as Administrator	"Every person signs in with their own account; every click you see is recorded against them."
0:30	Dashboard	Point at risks by band, control coverage, overdue actions, KRIs in red/amber, approvals waiting	"This is the CRO's morning view. Every number is computed live from the database; nothing is typed in."
2:00	Bell, top right	Open it	"Problems come to you: approvals waiting, KRI breaches, overdue actions."
2:30	Heatmaps	Show Inherent, then Residual, then Movement; click the top-right cell	"Inherent is the risk with no controls; residual is after controls. The arrows are the value our controls deliver. Click a cell and you see exactly which risks sit there."
4:00	Risk register	Show filters, search "ERP", open the ERP outage risk	"One register for the whole company, ten departments, searchable and filterable. Here is our top risk."
5:00	Risk page	Walk the page: 20 Critical → 9 Moderate, applied controls, actions, linked incident, approval history	"Everything about one risk on one page: how bad, what we do about it, what has happened, who approved it."

Time	Screen	Do this	Say this
6:30	Switch to the Assessor window	Risk register → **Add risk**: "Key supplier goes bankrupt during peak season", category Third Party, process Procure to Pay, owner Kenji Watanabe	"A department head adds a new risk. It starts as a draft."
8:00	Inherent assessment	Rate likelihood 4, impact 5, add a description, Save	"Four times five is twenty: Critical. The scale and the bands are the company's, set once in Settings."
9:00	Risk page → Apply control	Pick "Vendor due-diligence questionnaire" from the library, set effectiveness, Apply	"Controls are written once in the library and reused. Testing evidence travels with them."
10:00	Risk page	Click **Submit for approval**; point out there is no Approve button	"The person who made it cannot approve it. That is enforced by the server, not just hidden."
11:00	Switch to the Risk Manager window	Risk register → view **Awaiting approval** → open the new risk → Approve	"A second person checks. Approver and time are recorded."
12:00	Approvals	Show Waiting for me / My requests / All; open a rejected request and its comment	"Multi-step sign-offs, in order, by role. A rejection must say why."
13:00	Key risk indicators	Open "Unplanned IT outage hours", show the history chart and thresholds; record a reading of 13	"KRIs are early warnings. The app colours each reading itself: 13 is past the red line of 12, so it turns red."
14:30	Risk appetite	Show a category's tolerance vs computed exposure	"The board sets appetite; the app computes exposure from the rated risks, so nobody can massage it."
15:30	Reports	Risk register report → find the new risk; show CSV export and Print	"Board pack in one click, always current."

Time	Screen	Do this	Say this
16:30	Audit trail	Search the new risk's name; show Created, Submitted, Approved with names; point at the integrity seal	"Every step, by whom, when. The seal re-checks the whole chain each time: if anyone edits history, it breaks."
17:30	Settings	Change currency to EUR, show money values change; change it back	"One switch sets currency and score bands for everyone."
18:00	Viewer window	Show the register with no Add, Edit or Approve buttons	"Executives and guests can read everything and change nothing."
18:30	Ctrl+K	Type "ransomware" and jump to it	"Find anything in two keystrokes."
19:00	Wrap up	Back to the Dashboard	"One register, one scale, enforced sign-off, live reporting and a tamper-evident trail. Questions?"

If you only have 5 minutes: Dashboard → Heatmap (Movement) → ERP outage risk page → Approvals → Audit trail with the seal.

If they want depth: Vendors (tiers, overdue reviews), Incidents linked to risks, Business continuity (RTO/RPO), Scenarios (stressed loss), Policies (overdue review dates), the mitigation-plan hierarchy.

Live test cases

Run these the day before as a dress rehearsal; any of them can also be shown live when a guest asks "what happens if…". Tick each one off.

ID	Area	Steps	Expected result
T01	Sign-in	Sign in with a wrong password	"Invalid" message; no hint whether the e-mail exists
T02	Sign-in	Sign out, then press the browser Back button	Sign-in page, not the app: the session is gone

ID	Area	Steps	Expected result
T03	Dashboard	Note the number of Critical risks; rate a new risk 4 × 5; reload	Critical count goes up by one
T04	Register	Search "supplier"	Only matching risks; count updates; letter case ignored
T05	Register	Add a risk with an empty statement	Form refuses and says the statement is needed
T06	Register	Export CSV	File downloads with the same rows as the screen's filter
T07	Inherent	Rate 4 × 5 and save	Risk shows 20 · Critical; an assessment record appears in the history with date and author
T08	Controls	Apply a library control to a risk	Control listed on the risk page; the control library shows it linked to that risk
T09	Residual	Rate residual 2 × 3	Residual 6 · Low; the heatmap Movement mode shows an arrow from 20 to 6
T10	Maker-checker	As Assessor, submit a risk	Status Submitted; no Approve button for the Assessor
T11	Maker-checker	As Risk Manager, open **Awaiting approval** and approve it	Status Approved; approver and time recorded
T12	Maker-checker	As Risk Manager, create a risk, submit it, then try to approve it	Refused: you cannot approve your own work
T13	Approvals	Reject a request with an empty comment	Refused: a rejection needs a comment
T14	Viewer	Sign in as Viewer; open the register, a risk, the control library	Everything readable; no Add, Edit, Delete, Approve buttons
T15	Viewer	Open Users or Settings from the address bar	Not allowed: these pages are for administrators
T16	KRIs	Record 13 on "Unplanned IT outage hours" (red at 12)	Reading shows red; the bell and the dashboard count a KRI breach

ID	Area	Steps	Expected result
T17	KRIs	Record 14 on "Operating cash buffer" (lower is worse, red at 15)	Reading shows red, because for this KRI a low value is bad
T18	Appetite	As Assessor, try to edit a risk appetite statement	Not allowed: only approvers change appetite
T19	Control library	Try to delete a control applied to a risk	Refused with a message: retire it instead
T20	Settings	Change currency to EUR; open Incidents and Dashboard	Money shows in EUR everywhere (amounts are not converted); switch back
T21	Settings	Move the Critical band to start at 20; open the Heatmap	Colours change everywhere; switch back to 16
T22	Audit trail	Search for a risk you changed	Create, update, submit and approve entries with names and times; seal shows verified
T23	Search	Ctrl+K, type "ransom"	The ransomware risk is offered; Enter opens it
T24	Theme	User menu → dark theme	Whole app switches; printing still uses white paper
T25	Mobile	Open the app on a phone	Sidebar becomes a drawer; pages fit the screen

Edge cases and how the app handles them

These are the "what if" questions experienced risk and audit people ask. Each answer is built in; several are good to show deliberately.

Situation	What Pericope does	Why it matters
A risk has no ratings yet	Shows "Not rated" with a hatched badge and a Rate link; counted separately on dashboards	No invented scores; gaps are visible

Situation	What Pericope does	Why it matters
Someone tries to approve their own work	Refused by the server, even for an Administrator	Segregation of duties holds even if the browser is tampered with
Two managers decide the same request at the same moment	Only the first decision is kept; the second person is told it changed	No double or contradictory approvals
Two people edit the same record	The later save re-reads the record first, so fields the other person changed are not wiped	No silent data loss
A rejection with no reason	Refused	The submitter always knows what to fix
A user is deactivated or their role changes while signed in	Signed out at once	Leavers lose access immediately
5 wrong passwords	Account locked for a while; sign-in attempts are rate-limited	Stops password guessing
Laptop left open	Signed out after the idle time in Settings, across all tabs	No unattended sessions
Deleting a risk that has controls, actions and assessments	The dialog lists what will be removed; dependants go with it	No orphaned records
Deleting a control that is used by risks	Refused; retire it instead	Evidence for past assessments stays intact
A KRI where low is bad (e.g. cash buffer)	Direction "lower is worse" reverses the traffic-light rule	Correct colours for every kind of indicator
A continuity plan with RPO larger than RTO	The database refuses it	Impossible recovery targets cannot be saved
An incident is closed	Closed date is filled in automatically; cleared if reopened	Accurate time-to-close figures
A policy's review date passes	Shown as overdue, worked out from the date	No manual status to forget

Situation	What Pericope does	Why it matters
Currency changed in Settings	All money is shown in the new currency; amounts are not converted, and Settings warns about this	No surprise conversions of recorded losses
A CSV import with some bad rows	Good rows load; each bad row is listed with its reason	No "success" message that hides failures
The database is unreachable	Screens say the data could not be loaded, instead of showing empty or fake data; the API's `/ready` check reports it	Nobody makes decisions on blank screens
A module's tables are missing	The screen says the module is not set up yet	Partial installs fail politely
Someone edits the audit history directly in the database	The integrity seal shows the chain is broken	Tampering is detected
A very long list	Lists are paged on the server; totals are exact	Fast with thousands of risks
Small screens	Sidebar becomes a drawer; tables and cards reflow	Usable on a phone in a meeting

If something goes wrong during the demo

Stay calm and keep talking about the concept while you fix it. Most fixes take under a minute.

What you see	Likely cause	Fix
Screens say data could not be loaded	API stopped, or the database is unreachable	In the API window press Ctrl+C, then `npm --prefix api run dev`; open `/ready`. Still failing: run `node api/scripts/check-db.mjs` and follow its line

What you see	Likely cause	Fix
`/ready` shows `"database":"unavailable"`	Database address, client id or secret wrong; or the Autonomous Database is stopped	`node api/scripts/check-db.mjs`; in OCI check the database is Available (Always Free databases stop after 7 days without use)
Website does not open at all	Web app not running	Second terminal: `npm run dev`, wait for "Ready"
Sign-in says invalid for a correct password	Account locked after failed tries, or wrong account	Wait a few minutes, or sign in as Administrator and reset that user's password under Users
Signed out in the middle of the demo	Idle timeout	Sign in again; raise the idle minutes in Settings before the next demo
A button you expect is missing	You are signed in as a role that cannot use it	Check the name in the user menu; switch to the right window
"Cannot approve your own…"	You are approving something you created	Approve from the Risk Manager window, which did not create it
Pages look empty after re-installing the database	Browser still holds old data	Reload the page (Ctrl+Shift+R)
Audit trail seal shows broken	The API's data folder was deleted or copied between machines	Expected after a reset; say the chain starts again from the reset, and keep the `api/data` folder in future
Everything is slow	Free-tier database waking up	First load after a pause can take 10–20 seconds; open the Dashboard once before the guest arrives
Network is down	No internet	Switch to the backup screenshots; offer a follow-up session

Golden rule: never open `api/.env` or the database console on the shared screen while fixing something. Turn the screen off or switch to slides first.

Questions guests ask

Answer honestly; where something is not built yet, say it is on the roadmap.

Where is our data stored? In your Oracle Autonomous Database. The web app keeps nothing except display preferences (theme, density) in the browser. User accounts and the audit chain are kept by the API server, and the audit log is also copied into the database.

How is it secured? Named accounts with strong passwords and lockout; a secure, httpOnly session cookie; the API checks every request's role on the server; the database only answers the API (with an OAuth client), never the browser directly; every change is audited and sealed.

Can people approve their own work? No. The server refuses it, whatever the role.

Can we bring in our existing risk register? Yes: CSV import on the risk register reports any row it could not load. Exports are CSV too.

Can we use our own scoring? The 5 × 5 scale is fixed; where the bands start (Moderate, High, Critical) is set in Settings, and colours follow everywhere.

Which currencies? Ten: USD, EUR, GBP, INR, JPY, AUD, SGD, AED, CAD, CHF, set once for the organisation.

Does it follow a standard? It follows the RCSA method with inherent and residual risk, the approach used under common enterprise risk frameworks. Mapping controls to named frameworks is shown as text today; full framework mapping is on the roadmap.

Can it connect to our other systems? The API is documented (OpenAPI at `/api/openapi.json`) and the database is Oracle, so data can be read or loaded by other tools.

Single sign-on? Not yet; on the roadmap. Today it uses its own accounts.

Notifications by e-mail? Not yet; on the roadmap. In-app, the bell shows what needs attention.

Evidence uploads (documents, screenshots)? Not yet; evidence is recorded as text notes today. On the roadmap.

AI features? Not in this version; on the roadmap.

How is it hosted? Two small Docker containers (web app and API) behind HTTPS, plus Oracle Autonomous Database. It can also run on a plain Node.js server.

How long to roll out? The database installs with one script in minutes; then load your reference data (departments, processes, risk categories) into the database, import your risks by CSV, create user accounts in the app and run the first cycle. Reference lists are

read-only in the app today; editing them in the app is on the roadmap.

Does it work on phones? Yes, the layout adapts; it is best on a laptop for data entry.

Is the demo data real? No: Meridian Group and its people are invented. Your data replaces it.

Glossary

Term	Meaning
ERM	Enterprise risk management: managing all of a company's risks in one consistent way
GRC	Governance, risk and compliance
RCSA	Risk and control self-assessment: departments assess their own risks and controls each cycle
Assessment cycle	A review period (e.g. a quarter) with dates and a deadline
Risk register	The master list of risks
Likelihood	How probable the risk is, 1 (Rare) to 5 (Almost certain)
Impact	How bad it would be, 1 (Insignificant) to 5 (Severe)
Score	Likelihood × impact, 1–25
Band	Low, Moderate, High or Critical, from the score
Inherent risk	The risk before any controls
Residual risk	The risk after controls
Control	Something that prevents, detects or corrects a risk (e.g. MFA, reconciliation)
Design / operating effectiveness	Whether a control is well designed / whether it works in practice
Mitigation plan	A planned piece of work to reduce a risk
KRI	Key risk indicator: a number with thresholds that warns early
KPI	Key performance indicator: a number measured against a target

Term	Meaning
Risk appetite	How much risk the board is willing to take in a category
Tolerance	The score above which a category is outside appetite
Maker-checker	One person makes a change, a different person approves it
SLE	Single loss expectancy: estimated money lost if the risk happens once
RTO / RPO	Recovery time objective (how fast to recover) / recovery point objective (how much data may be lost)
Audit trail / seal	The record of every action / the hash chain that proves it was not altered
ORDS	Oracle REST Data Services: how the API talks to the Oracle database